

INTRODUCCIÓN COMPLIANCE

O descoñecemento dunha lei non te exime do seu cumprimento.

Persoas Físicas → Persoas

Persoas Xurídicas → Organizacións

Codigo Penal → Modificado en 2010 para tratar de aclarar as situacións das ORGs

As empresas teñen unha responsabilidade xurídica propia que vai máis alá das accións individuais dos seus traballadores, e esta responsabilidade non desaparece aínda que a sociedade se disolva.

Para previr delitos, as organizacións están obrigadas a manter un control activo sobre o seu persoal. A vixilancia non só debe centrarse en ilícitos penais, senón tamén en evitar infraccións administrativas e manter un comportamento que a sociedade considere ético.

Compliance → Medidas organizativas que toma unha empresa para, dun xeito proactivo, procurar coñecer toda a normativa, que lle poida ser de interese.

Para que ese control e cumprimento sexan factibles, as ORGs teñen que implantar sistemas de automatización de tarefas, delimitar responsabilidades, establecer mecanismos de reacción e formar aos empregados.

Na actualidade o 94% de empresas son 1-9 empregados ou autónomos e non poden dedicar recursos a implantación de mecanismos de control normativo.

BO GOBERNO

Implantar un sistema de boas prácticas de cumprimento legal, se ben parece un concepto unanime, en verdade non é un obxectivo común para todas as empresas actuais.

É importante non realizar comportamentos pouco éticos para evitar unha perda de reputación que poida afectar as operacións e así xerar confianza nos clientes, provedores ou mercados.

Actualmente no compliance non se nombra a ética aínda que representa unha parte moi importante dela, levando a xerar en grandes empresas postos específicos coma é o Chief Ethics and Compliance Officer.

CUMPRIMENTO

Proactividade → Permitirá as organizacións mitigar riscos e protexer a súa actividade e os seus clientes en vez de tratar de solucionar problemas legais cando aparezan.

Accions a implantar →

- Cultura de cumprimento normativo
- Facilitar a formación en base ao nivel necesario de coñecemento do traballador
- Incluir o seguimento de cambios normativos
- Monitorización de actividades relacionadas co cumprimento normativo
- Poñer especial esforzo en coidar os datos

Compliance officer → Encargado de cumprimento normativos dunha ORG

CCO → Chief Compliance Officer → Maior autoridade e responsabilidade coa capacidade de promover e executar medidas específicas de prevención, formación ou recomendación de sancións

En España ningunha reforma do Código Penal refírese a existencia do “Compliance Officer”, mais si que establecen o deber de supervisión que na práctica se corresponden coa función deste posto.

FUNCIÓN DO CUMPRIMENTO NORMATIVO

En base ao incremento da complexidade dos distintos tipos de obrigas dunha empresa (independentemente do tamaño), estanse a aumentar os requirimentos de compliance, levando tamén as distintas autoridades a referenciar máis a boa xestión do cumprimento normativo e as boas prácticas.

Tarefas básicas da función de cumprimento →

- Identificación, interpretación e actualización das obrigas dunha ORG
- Difusión das obrigas
- Asignación de responsabilidades
- Desenvolvemento de procedementos de integración
- Monitorización e auditoría
- Coordinación coas autoridades reguladoras
- Xestión de canles de denuncias internas
- Actualización e mellora continua

Responsable de cumprimento debe ter a suficiente autoridade para que as súas recomendacións sexan aceptadas e implantadas.

COMPLIANCE EN PEQUENAS ORGANIZACIÓNS

Compliance tende a asociarse coas grandes organizacións, hai que ter en consideración que as leis non distinguen as obrigas polo tamaño das organizacións, polo que as empresas pequenas tamén deben de cumprir cos requerimentos.

Non todo son desvantaxes nas pequenas organizacións, xa que pola cercanía dos empregados, actividades en común e conversas informais, poden facilitar o establecemento e consolidación dunha cultura do cumprimento.

Proporcionalidade → Implica ponderar circunstancias particulares cando haxa que valorar incumprimentos → O tamaño da organización se terá en conta, ademáis do tipo de negocio, mercados no que opera e terceiros.

A solución a unha organización que sobrepasa as súas capacidades, nunca debería ser o incumprimento normativo.

RELACIÓNS CON TERCEIRAS PARTES

Terceiros → Persoas ou entidades que unha organización contrata e non forman parte dela. → Realizan accións en nome da organización (mesma consideración e relevancia).

Na actualidade non é posible evitar o dano á reputación que poida ocasionar un terceiro por comportamentos pouco éticos ou incumprimento normativo, esto implica un seguimento coidadoso do traballo dos terceiros.

Será imprescindible coñecer quen son os terceiros cos que se ten relación e valorar se hai suficiente persoal para controlar as actividades que se realizan por encargo.

As organizacións poden sufrir danos reputacionais e incluso responsabilidade civil ou penal cando traballan con terceiros, especialmente se estes son descoñecidos, operan en contornas con pouca supervisión, teñen diferenzas culturais ou legais importantes, non coñecen as normas internas ou só buscan beneficios a curto prazo.

Para reducir estes riscos, é fundamental identificar e avaliar previamente a cada terceiro, manter rexistros actualizados, documentar o proceso de selección segundo o nivel de risco, establecer contratos claros e facer un seguimento continuo das súas actuacións.

NORMAS ISO, EN UNE

A xestión da organización Implica aspectos tan complexos que resulta conveniente dispoñer de guías para actuar con seguridade e ter un bo nivel de calidade

ISO → International Organization of Standardization → 172 países → +20000 normas

Algunhas desas normas son certificables → Unha entidade externa verifica que o traballo real segue as indicacións do estándar, demostrando alto nivel de calidade

Se unha org utiliza unha iso impoñe un traballo extra con intención de obter vantaxes futuras:

Fiabilidade, rendemento, calidade, aumento de negocio, redución de riscos, sustentabilidade, innovación

UNE → Una Norma Española → Equivalencia de estándar Española creada polos Comités Técnicos de Normalización

EN → Normas europeas elaboradas por expertos de estados membros

Adaptacións fusionan siglas → UNE-EN ISO9001 → Española baseada en una europea que a su vez es basada en la iso 9001

SISTEMAS DE XESTIÓN COMPLIANCE

Conxunto de políticas, procedementos e ferramentas con intención de previr incumprimentos e promover unha cultura ética.

Primeiros Pasos:

- Identificar incumprimentos
- Identificar medidas de control + ferramentas a incluír
- Establecer procedementos de monitorización

ANÁLISE E XESTIÓN DE RISCOS

Tarefa de pensar en riscos futuros para así minimizar impactos con anterioridade en calquera ámbito da org.

Análise de riscos → identificar ameazas, vulnerabilidades e posibles impactos derivados de incidentes de seguridade → Ten que avaliar a probabilidade e gravidade das consecuencias para os dereitos e liberdades das persoas físicas.

Xestión de Riscos → A Xestión de riscos implica a definición, implementación e supervisión de medidas técnicas e organizativas axeitadas para reducir os riscos a niveis aceptables → Medidas técnicas / organizativas e/ou de revisión continua

ISO 27001

Estandar certificable que define requisitos para establecer, implementar, manter, e mellorar un SXXI → Obxectivo: Protexer confidencialidade, integridade e dispoñibilidade dos datos aplicable a calquer sector ou tamaño de org

C4 → Contexto da ORG → Proceso de análise de riscos que permite definir o alcance do SXXI e os criterios para a avaliación de riscos

C6.1.2 → Avaliación de riscos → Identifícanse activos, ameazas e vulnerabilidades e aválíanse os riscos segundo probabilidade e impacto.

C6.1.3 → Tratamento dos riscos → Defínese e execútase un plan de tratamento dos riscos seleccionando opcións (mitigar, evitar, transferir ou aceptar) e documentando os controis na SoA.

C8 → Operación → Implementanse procesos que aseguran a coherencia e eficacia das medidas de seguridade definidas

C9 → Avaliación do desempeño → Realízanse seguimento, medición, auditoría interna e revisión pola dirección para comprobar a eficacia dos controis e o risco residual.

C10 → Mellora → Establécense accións correctivas e mellora continua para actualizar e perfeccionar o SXXI ante cambios e non conformidades.

ANEXO A ISO 27001

O Anexo A da ISO 27001 inclúe 93 controis de seguridade que serven como guía de boas prácticas para protexer a información, garantindo a súa confidencialidade, integridade e dispoñibilidade (CIA) dentro dun Sistema de Xestión de Seguridade da Información (SXXI).

Estes controis non se aplican obrigatoriamente todos, senón que se seleccionan en función dos riscos identificados na organización. A súa aplicación e xustificación recóllese na Declaración de Aplicabilidade (SoA), onde se indica que controis son pertinentes e o seu estado de implantación.

Os controis organízanse en catro grandes bloques: organización (37) (políticas, xestión de activos, control de accesos, provedores e xestión de incidentes), persoas (8) (selección, formación, responsabilidades e confidencialidade), infraestrutura (14) (seguridade física e ambiental das instalacións e equipos) e tecnoloxía (34) (criptografía, seguridade de redes, xestión de vulnerabilidades, copias de seguridade e control de cambios).

Para tratar os riscos identificados (agás a súa aceptación), é necesario seleccionar e aplicar controis do Anexo A, apoiándose na ISO 27002 como guía de implementación e boas prácticas.

Como evidencia da avaliación de riscos e das medidas adoptadas, elabórase a Declaración de Aplicabilidade (SoA), onde se indica para cada control se é aplicable, se está implantado e a xustificación correspondente. O SoA pode ser un documento sinxelo, por exemplo unha táboa que recolla os controis aplicables, o seu estado e unha breve explicación da súa implantación.

AS PERSOAS XURÍDICAS

Persoa xurídica → Entidade formada por varias persoas físicas que ten personalidade xurídica propia, polo que pode asumir dereitos e obrigas de maneira independente dos seus membros.

As empresas constituídas como persoas xurídicas son básicas na actividade económica e poden ser suxeitos directos ou indirectos de actividades delitivas.

As actuacións ilícitas poden producirse por empregados ou responsables para obter beneficio para empresa ou ben por terceiros para lucrarse individualmente da empresa.

Por isto o Código Penal foi reformado no 2010 e no 2015, traendo a posibilidade de que a organización poida ser procesada e condenada por delitos cometidos polos empregados.

As empresas deben de establecer medidas de prevención que minimicen e dificulten que os empregados poidan cometer delitos, no caso de cumprimento, a persoa xurídica queda exenta de responsabilidade segundo o artigo 31 bis do Código Penal.

No apartado 5 deste mesmo artigo, establece os requirimentos mínimos que deben cumprir para poder eximirse de responsabilidade.

RESPONSABILIDADE

A responsabilidade penal das persoas xurídicas implica que unha empresa pode ser condenada por determinados delitos aínda que non se identifique a persoa física responsable. Esta responsabilidade non desaparece por cambios na estrutura da empresa, como fusións ou transformacións.

As persoas xurídicas poden responder por delitos económicos, informáticos, fiscais, contra os traballadores, o medio ambiente ou o mercado, entre outros. As sancións poden ser multas elevadas, suspensión ou peche de actividades, prohibición de contratar coa administración e incluso a disolución da empresa.

Non obstante, a colaboración coa xustiza, a reparación do dano ou a implantación de medidas de control e cumprimento normativo poden reducir a responsabilidade.

CÓDIGO PENAL E XURISPRUDENCIA

A partir das modificacións realizadas sobre o código penal xurdiron moitas dúbidas sobre a diferenciación de responsabilidades entre a persoa física e a xurídica. Para ese obxectivo de diferenciación xorde a xurisprudencia, que será o conxunto de sentenzas, decisións e criterios que xorden ao interpretar as leis, para así, en futuros casos evitar vacíos legais e facilitar a interpretación das leis.

A xurisprudencia é unha fonte indirecta do Dereito que complementa e interpreta as leis para facilitar a súa aplicación. Serve para unificar criterios, evitar contradicións e dar seguridade xurídica ao establecer como deben entenderse as normas. Ademais, as decisións dos tribunais superiores marcan doutrina obrigatoria para os inferiores e, a través da repetición de resolucións en casos semellantes, fórmanse criterios estables de interpretación. En España → Tr. Supremo → Tr. Constitucional → Tr. Superior de Xustiza